

New ransomware is using a carefully disguised payload

According to recent research by Checkmarx and Phylum, an ongoing ransomware campaign targets well-known open source packages that regularly see close to 15 million installations every week and conceals its payload in an unusual method.

The campaign, which includes embedded malware, targets the well-known ‘requests’ package on Pypi and the ‘discord.js’ package on NPM, according to a blog post by Checkmarx researchers. When the ransomware is run, it encrypts the victim’s computer data and demands US\$ 100 in cryptocurrency to decrypt them.

Alik Koldobsky, a security researcher at Checkmarx, told *SC Media* that the payload is hidden in several key locations and only executes when the victims use the actual functions of the packages, unlike most open source attacks where malicious packages are run immediately after installation. This makes the campaign difficult to detect by many security scanners.

Because the malware payload is compatible with several different operating systems, the campaign can target a larger population. Although a complete attribution has not yet been made, researchers have found evidence that suggests the attacker is Russian -- the Telegram user account linked to the attack has a Russian phone number, and the attacker directly communicates with researchers in Russian.

The perpetrator's account is still able to distribute potentially dangerous packages on NPM and PyPi, where software supply chain assaults are common, even after Checkmarx reported the attacks. According to researchers, they will keep an eye out for any new activity.

contemporary application security best practices. Today, 70 to 90 per cent of applications employ open source code, making more businesses susceptible to attacks as threat actors take advantage of the repair gap.

Even when businesses patch tens of thousands of vulnerabilities each month, it takes contemporary remediation best practices to handle the constant stream of new vulnerabilities discovered and stop the vulnerability backlog from increasing. Open source software availability has grown by an estimated 25 per cent, yet the rise of open source vulnerabilities has outpaced that growth. The use of prioritisation and remediation technologies, as well as routine application security



scanning, is crucial because apps are the backbone of the global economy.

“As security debt continues to rise, it’s crucial to find a way to prioritise the vulnerabilities that pose the highest risk to avoid falling victim to an attack,” said Jeffrey Martin, VP product management at Mend. “Using remediation tools that can assess and prioritise the vulnerabilities that can most heavily impact systems is an important element to managing security debt. Organisations should not just pay attention to severity details though; to ensure effective prioritisation and remediation, they need to also look at the exploitation context of flaws on their own and in conjunction with others.”

ActiveState Artifact Repository is available for free for a limited period

ActiveState is providing the ActiveState Artifact Repository without charge in all ActiveState Platform tiers (including its well-liked Free Tier) for a limited period. In September 2022, the ActiveState Artifact Repository was made available, making it the first tool in the market to let businesses use ActiveState's secure build service to safely generate Python open source dependencies from source code. A closed-loop environment is thus created, maximising supply chain security, whereby all produced code is immediately stored for distribution in the company's own private ActiveState Artifact Repository.

Since its introduction, the ActiveState Artifact Repository has proven useful to ActiveState customers and interfaces with a number of other premier secure supply chain capabilities that are pre-integrated into the ActiveState Platform, such as curated collection of examined artefacts, functionality for resolving vulnerabilities, a certification programme for open source products, and a software bill of materials (SBOM).